

BÀI TẬP MÔN: AN TOÀN VÀ BẢO MẬT THÔNG TIN

Chủ đề: Chữ ký số trong file PDF

Giảng viên: Đỗ Duy Cốp

Họ tên: Nguyễn Mạnh Hiếu

MSSV: K225480106020

BÀI LÀM

1. Mô tả các thành phần chính của 1 file PDF có chữ ký số

- ❖ **Catalog:** object gốc của file PDF, điểm vào cho cấu trúc tài liệu (tham chiếu đến Pages, AcroForm, Names, etc.).
- ❖ **Pages tree:** cây phân cấp quản lý các trang (Nodes: /Type /Pages, con là /Kids gồm các Page objects).
- ❖ **Page object:** mô tả một trang (media box, resources, contents — chuỗi nội dung hiển thị).
- ❖ **Resources:** tập hợp font, xobject, color spaces, procsets... được Page hoặc Content stream sử dụng.
- ❖ **Content streams (/Contents):** chuỗi lệnh vẽ (PDF operators) nội dung trang; có thể nén và có nhiều stream.
- ❖ **XObject:** các đối tượng ngoại vi (hình ảnh, Form XObject — có thể tái sử dụng nội dung như subpage).
- ❖ **AcroForm:** dictionary chứa thông tin form fields (biểu mẫu), bao gồm danh sách field và appearance streams.
- ❖ **Signature field (widget):** một form field đặc biệt (typical: /FT /Sig) thể hiện vị trí chữ ký trên trang (widget annotation).
- ❖ **Signature Dictionary (/Sig):** dictionary chứa metadata chữ ký (và giá trị /Contents chứa PKCS#7/CMS). Thường nằm trong Signature field như /V hoặc tham chiếu tới một object chứa dictionary chữ ký.

- ❖ **/ByteRange:** mảng 2 hoặc 4 số (offset/length cặp) chỉ ra các vùng byte của file được bao hàm trong bản ký — vùng chứa /Contents thường bị bỏ qua khi tính hash.
- ❖ **/Contents:** trường chứa giá trị chữ ký (thường là CMS/PKCS#7 bytes — có thể chứa timestamp token, certs, CRLs, v.v.).
- ❖ **Incremental Updates:** cơ chế append-only của PDF — chữ ký thường thêm dưới dạng revision mới, giữ nguyên bytes cũ; cho phép nhiều chữ ký theo thứ tự.
- ❖ **DSS:** vùng (thường nằm trong trailer hoặc phần names) chứa thông tin xác minh: certificates, CRLs, OCSP responses, timestamp tokens, và các dữ liệu hỗ trợ để đạt LTV (Long-Term Validation).

2. Các object refs quan trọng & vai trò

Catalog: entry point; cần để truy xuất /Pages và /AcroForm. Nếu file có signature liên quan tới forms thì AcroForm từ Catalog dẫn tới SigField.

Pages (node) → Page object: nơi chứa /Contents và /Resources; signature widget có thể là annotation trên Page.

Page.Annots / Widget: chứa tham chiếu đến Signature field (vị trí hiển thị, appearance) — giúp trình xem biết hiển thị hộp chữ ký.

AcroForm / Fields: danh sách các field; Signature field thường nằm ở đây (field dictionary chứa /FT /Sig và trường /V hoặc /DV để tham chiếu SigDict).

Signature Field (/FT /Sig) object: tham chiếu tới Signature dictionary qua /V (Value) hoặc /DV; widget object xác định vị trí (rect) và appearance.

Signature dictionary (/Sig): chứa metadata ký như /Filter, /SubFilter, /ByteRange, /Contents, /M, /Name, /Reason, /Location, /Cert (tùy tài liệu). Đây là object quan trọng nhất để lưu và đọc chữ ký.

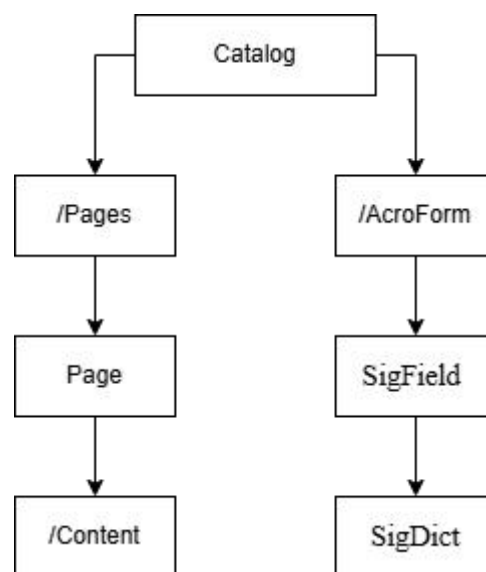
/Contents (trong SigDict): chứa bytes chữ ký (CMS/PKCS#7 hoặc các dạng khác) — khi đọc, parser sẽ trích bytes này để kiểm tra chữ ký, chứng chỉ, và attributes (như timestamp token).

/ByteRange (trong SigDict): chỉ định chính xác vùng bytes được băm; bắt buộc để xác định chính xác phần nào của file được ký (đặc biệt do incremental updates / /Contents có kích thước cố định khi viết chữ ký).

Trailer / Incremental updates: mỗi revision có thể thêm objects mới; chữ ký được lưu trong revision append; khi xác minh, parser phải tính toán băm theo /ByteRange trên toàn file hiện thời.

DSS (PAdES): không bắt buộc trong PDF tiêu chuẩn nhưng PAdES khuyến nghị — chứa chứng chỉ, CRL/OCSP, timestamp tokens và cấu trúc giúp xác minh dài hạn. DSS làm cho quá trình xác minh độc lập khỏi nguồn mạng ngoài.

3. Sơ đồ Object



4. Thời gian ký được lưu ở

❖ */M trong Signature dictionary (SigDict)*

- Dạng: một chuỗi văn bản theo chuẩn PDF (ví dụ: (D:20251031...Z) theo PDF date format).
- Tính chất: claimed signing time do người ký hoặc phần mềm tạo chữ ký ghi vào metadata. Đây là thông tin dạng văn bản, không được bảo

chúng về tính không thể chối bỏ (non-repudiation) vì không có chữ ký riêng cho trường này nếu attacker có thể sửa toàn bộ object rồi cập nhật Contents.

- Giá trị pháp lý: thường không đủ mạnh để chứng minh thời điểm thực sự (vì có thể bị giả mạo nếu không kèm timestamp được bảo chứng bởi bên thứ ba).
- ❖ *Timestamp token (RFC 3161) trong PKCS#7/CMS (attribute timeStampToken)*
 - Dạng: là một token do một Timestamping Authority (TSA) tạo, được nhúng vào signed attributes của CMS/PKCS#7 (hoặc như một attribute trong SignedData). Token này chứa thời gian được TSA ký bằng khoá riêng của TSA.
 - Tính chất: timestamp RFC3161 là bằng chứng thời gian độc lập (trusted) — TSA xác nhận rằng một digest (hoặc dữ liệu) tồn tại vào lúc thời gian được ghi trong token.
 - Giá trị pháp lý: mạnh hơn /M vì timestamp được ký bởi TSA; giúp chứng minh tài liệu (hoặc digest) đã tồn tại trước thời gian nhất định.
- ❖ *Document timestamp object (PDF-specific/PAdES Document TimeStamp)*
 - Dạng: một signature object chuyên biệt trong PDF gọi là document timestamp (ví dụ /Type /Sig với subfilter thích hợp) theo PAdES — khác với signature người dùng vì mục tiêu chính chỉ là timestamp; thường yêu cầu dùng TSA và RFC3161 token.
 - Tính chất: document timestamp ký toàn bộ document revision (hoặc phần xác định) với mục đích chỉ ra thời điểm; có thể không gắn với người ký cụ thể.
 - Giá trị pháp lý: cũng là timestamp được chứng thực, dùng khi cần chứng minh thời điểm tồn tại của tài liệu (PAdES định nghĩa cách tích hợp).

- ❖ *DSS (Document Security Store) — lưu trữ các timestamp và dữ liệu xác minh*
- Dạng: một structure (theo PAdES) chứa các chứng chỉ, CRL, OCSP responses, và timestamp tokens (nếu đã lấy) để cho phép xác minh offline/LTV.
- Tính chất: DSS không thay thế timestamp nhưng là nơi tập trung để lưu các evidence (bao gồm RFC3161 tokens) cần cho xác minh lâu dài.
- Giá trị pháp lý: DSS giúp duy trì bằng chứng về trạng thái chứng chỉ và timestamp đã từng tồn tại tại thời điểm ký, tăng khả năng chứng minh khi chứng chỉ/OCSP/CRL không còn trực tuyến.

5. Sự khác biệt chính giữa /M và timestamp RFC3161

- ❖ Nguồn tin cậy:
 - /M: do signer (hoặc phần mềm) ghi — không có bên thứ ba chứng thực; dễ bị sửa nếu attacker có quyền append revision hoặc chỉnh sửa file trước khi hash/chữ ký được bảo vệ.
 - RFC3161 timestamp: do TSA (bên thứ ba đáng tin cậy) cấp và chính TSA ký token — có khả năng chứng thực thời điểm độc lập.
- ❖ Bảo đảm và phạm vi bảo vệ:
 - /M là một trường metadata nằm trong chính signature dictionary; trường này không độc lập được bảo đảm nếu attacker thay đổi signature object cùng lúc với /Contents (tuy trong thực tế /Contents chứa chữ ký trên /ByteRange loại trừ vùng /Contents, nhưng nếu attacker có thể tạo signature mới họ sẽ ghi lại /M mới). Nói cách khác, /M chỉ có giá trị nếu chính /Contents (signature) bao hàm và bảo vệ trường đó thông qua dữ liệu đã được signed attributes; nếu /M chỉ là plain text ngoài signed attributes thì không an toàn.
 - RFC3161 timestamp ký một digest (thường digest của toàn bộ SignedData hoặc một digest của dữ liệu được timestamp) bởi TSA;

token này chịu tính chống giả mạo vì TSA ký nó — nó cung cấp bằng chứng thời điểm nằm ngoài quyền kiểm soát signer.

❖ Cách lưu trong PDF:

- /M là một entry trực tiếp trong SigDict.
- RFC3161 token thường nằm bên trong /Contents (PKCS#7) như một timeStampToken trong signed attributes hoặc như một embedded timestamp structure; đôi khi timestamp được lưu vào DSS như một phần của dữ liệu hỗ trợ.